Modelo de Amenazas - E-Commerce Platform

Owner: Walter Mancia
Reviewer: Cesar Minas
Contributors:
Date Generated: Fri Oct 09 2026

Executive Summary

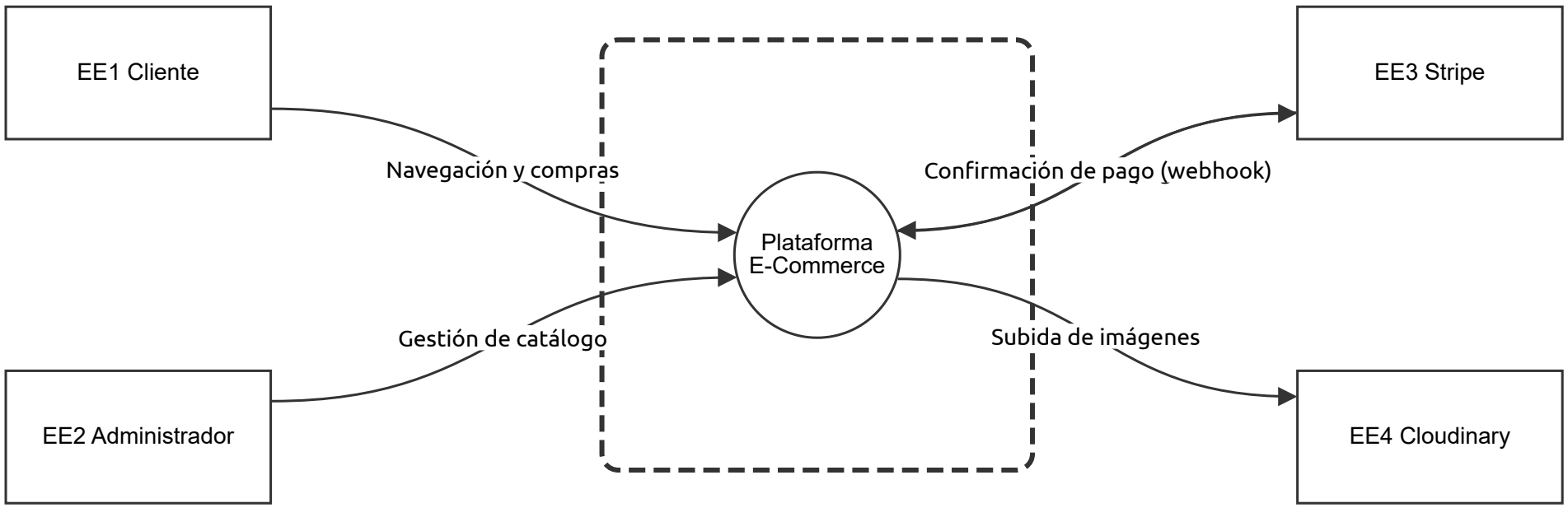
High level system description

Modelo de amenazas STRIDE de la plataforma E-Commerce (React, Express, MySQL, Stripe, Cloudinary). Tarea de Seguridad en Aplicaciones, UMG.

Summary

Total Threats	23
Total Mitigated	0
Total Open	23
Open / Critical Severity	0
Open / High Severity	13
Open / Medium Severity	8
Open / Low Severity	2

DFD Nivel 0 - Contexto



DFD Nivel 0 - Contexto

EE1 Cliente (Actor)

Description: Usuario final que navega y compra.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

EE2 Administrador (Actor)

Description: Gestiona catálogo e imágenes.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Plataforma E-Commerce (Process)

Description: SPA, API REST y base de datos.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

EE3 Stripe (Actor)

Description: Pasarela de pagos (tercero).

Number	Title	Type	Severity	Status	Score	Description	Mitigations

EE4 Cloudinary (Actor)

Description: Almacén de imágenes (tercero).

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Navegación y compras (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Gestión de catálogo (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Solicitud de pago (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

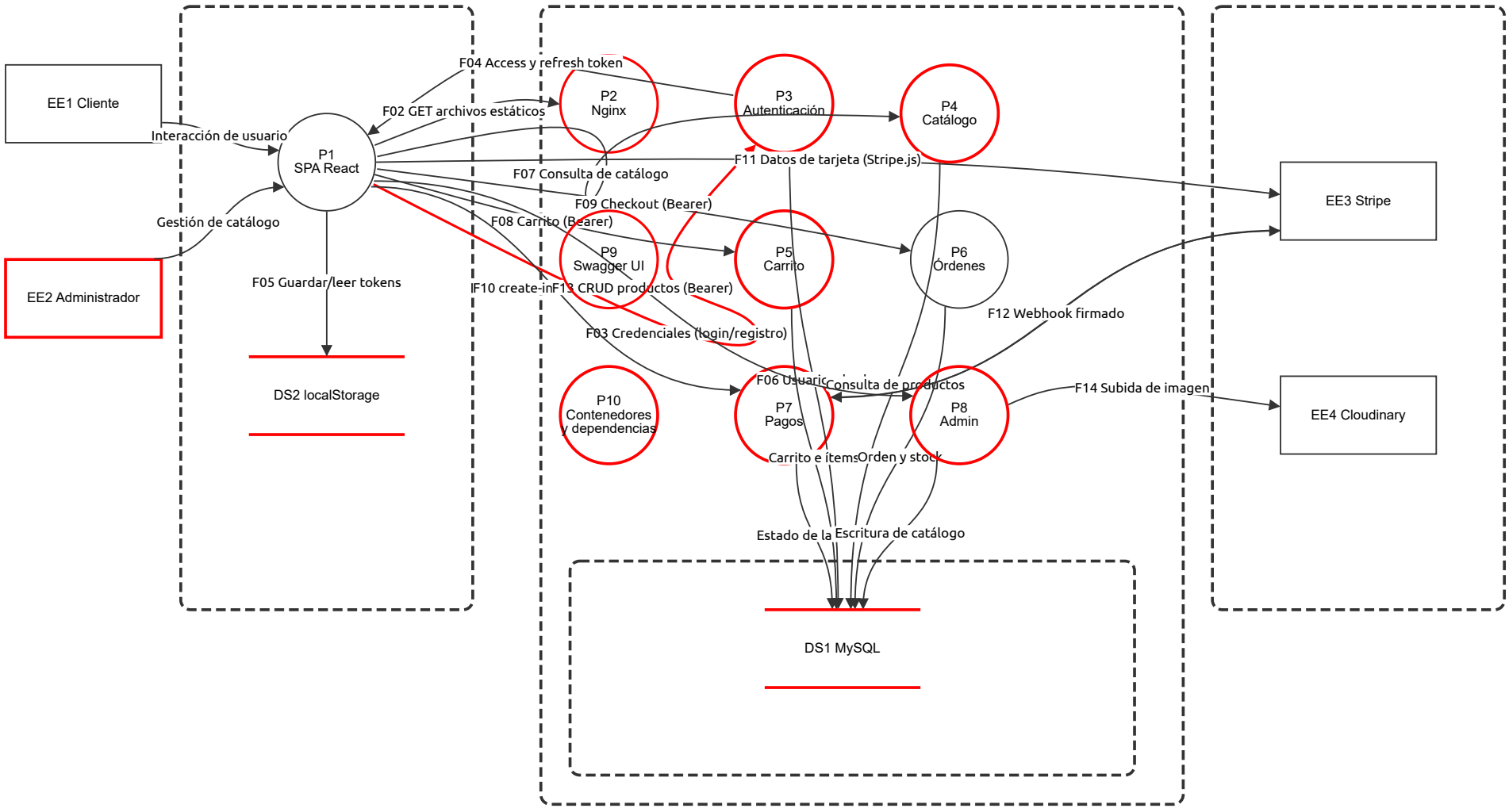
Confirmación de pago (webhook) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Subida de imágenes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

DFD Nivel 1 - Procesos y limites de confianza



DFD Nivel 1 - Procesos y limites de confianza

EE1 Cliente (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

EE2 Administrador (Actor)

Description: Cuenta con rol admin.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
23	T23 [Alto] Cuenta admin sin MFA	Spoofing	High	Open		El administrador autentica solo con contraseña; su compromiso da control del catálogo y precios. Nivel de riesgo: Alto (puntaje 8). Categorías STRIDE: S, E. Evidencia: auth.service.js, product.routes.js.	MFA TOTP obligatorio, sesiones cortas para admin, auditoría de cambios.

P1 SPA React (Process)

Description: Aplicación React + Zustand en el navegador.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

DS2 localStorage (Store)

Description: Almacena access y refresh token.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	T03 [Alto] Tokens en localStorage sin CSP	Information disclosure	High	Open		Access y refresh token se guardan en localStorage; un XSS o dependencia comprometida los exfiltra. No hay CSP ni cabeceras de seguridad. Nivel de riesgo: Alto (puntaje 6). Categorías STRIDE: I, S. Evidencia: api.js, authStore.js, nginx.conf.	CSP estricta, tokens en cookie HttpOnly + SameSite, sanitización de entradas.

P2 Nginx (Process)

Description: Sirve la SPA por HTTP (puerto 80).

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	T05 [Crítico] Tráfico sin TLS	Information disclosure	High	Open		Nginx escucha solo en el puerto 80 y la API en el 3000 sin TLS: credenciales y tokens viajan en claro. Nivel de riesgo: Crítico (puntaje 9). Categorías STRIDE: I, T. Evidencia: nginx.conf, docker-compose.yml.	TLS 1.2+ en Nginx y API, HSTS, redirección 80 a 443.

P3 Autenticación (Process)

Description: /auth: register, login, refresh-token, me.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	T01 [Crítico] Sin rate limiting en autenticación	Spoofing	High	Open		No hay límite de intentos ni bloqueo en /auth/login, /auth/register y /auth/refresh-token: fuerza bruta, credential stuffing y saturación de CPU (bcrypt). Nivel de riesgo: Crítico (puntaje 12). Categorías STRIDE: S, D. Evidencia: app.js, auth.routes.js.	express-rate-limit por IP y por cuenta, bloqueo progresivo, captcha, MFA y alertas por picos de 401.
4	T04 [Alto] Refresh token sin rotación ni revocación	Spoofing	High	Open		Refresh token de 7 días sin rotación, sin lista de revocación ni logout en servidor; refreshTokenService no valida is_active. Nivel de riesgo: Alto (puntaje 6). Categorías STRIDE: S, E, R. Evidencia: auth.service.js, jwt.utils.js.	Rotación con detección de reuso, almacenamiento revocable, validar is_active y estado de la cuenta.
15	T15 [Medio] Enumeración de usuarios en registro	Information disclosure	Medium	Open		El registro responde 409 indicando que el correo ya existe. Nivel de riesgo: Medio (puntaje 4). Categorías STRIDE: I. Evidencia: auth.service.js.	Respuesta genérica y verificación por correo.
19	T19 [Alto] Sin validación de entrada en autenticación	Spoofing	High	Open		Sin política de contraseña, longitud máxima ni formato; contraseñas enormes consumen CPU en bcrypt. Nivel de riesgo: Alto (puntaje 6). Categorías STRIDE: S, D. Evidencia: auth.routes.js, auth.controller.js.	express-validator: email válido, contraseña 12 a 72 caracteres, límites de body.
20	T20 [Medio] JWT sin algoritmo, iss ni aud fijados	Elevation of privilege	Medium	Open		jwt.verify no fija algoritmos y el rol del token no se revalida contra la BD durante 15 min. Nivel de riesgo: Medio (puntaje 3). Categorías STRIDE: E. Evidencia: jwt.utils.js, auth.middleware.js.	algorithms: [HS256], iss y aud; revalidar estado de usuario en rutas sensibles.

P4 Catálogo (Process)

Description: /products y /categories (público).

Number	Title	Type	Severity	Status	Score	Description	Mitigations
16	T16 [Medio] Productos inactivos expuestos	Information disclosure	Medium	Open		GET /products/id/:id no filtra is_active y devuelve productos eliminados lógicamente. Nivel de riesgo: Medio (puntaje 3). Categorías STRIDE: I. Evidencia: product.routes.js, product.repository.js.	Filtrar is_active en findProductById público.
18	T18 [Alto] Paginación sin tope y búsqueda LIKE	Denial of service	High	Open		limit no tiene máximo y la búsqueda LIKE %x% no usa índice. Nivel de riesgo: Alto (puntaje 6). Categorías STRIDE: D. Evidencia: product.service.js, product.repository.js.	Tope de limit (p. ej. 50), índice, caché y rate limiting.

P5 Carrito (Process)

Description: /cart (autenticado).

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	T02 [Crítico] Cantidades negativas o no validadas en carrito	Tampering	High	Open		quantity se acepta sin validar (negativos, no enteros). En checkout, stock - (-N) aumenta el stock y el total puede reducirse al compensar con un artículo caro. Nivel de riesgo: Crítico (puntaje 9). Categorías STRIDE: T. Evidencia: cart.service.js, order.service.js, CartItem.js.	Validar quantity entero >= 1 con tope; CHECK en BD; verificar total > 0 antes de crear la orden.

P6 Órdenes (Process)

Description: /orders/checkout. Detalle en Nivel 2.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P7 Pagos (Process)

Description: /payments: create-intent y webhook. Detalle en Nivel 2.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	T10 [Medio] Errores con detalles internos	Information disclosure	Medium	Open		El error handler devuelve err.message y el webhook incluye el mensaje de error de Stripe. Nivel de riesgo: Medio (puntaje 4). Categorías STRIDE: I. Evidencia: error.middleware.js, payment.service.js.	Mensajes genéricos al cliente; detalle solo en logs.

Interacción de usuario (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Gestión de catálogo (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F03 Credenciales (login/registro) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	T08 [Medio] CORS abierto	Spoofing	Medium	Open		cors() sin lista blanca de orígenes. Nivel de riesgo: Medio (puntaje 4). Categorías STRIDE: S, I. Evidencia: app.js.	Lista blanca de orígenes permitidos.

F04 Access y refresh token (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F05 Guardar/leer tokens (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F06 Usuario y hash (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F07 Consulta de catálogo (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Consulta de productos (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F08 Carrito (Bearer) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Carrito e ítems (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F09 Checkout (Bearer) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Orden y stock (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F10 create-intent (orderId) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Crear PaymentIntent (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F11 Datos de tarjeta (Stripe.js) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F12 Webhook firmado (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Estado de la orden (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F13 CRUD productos (Bearer) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Escritura de catálogo (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F14 Subida de imagen (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F02 GET archivos estáticos (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P8 Admin (Process)

Description: CRUD de productos y subida de imágenes (rol admin).

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	T11 [Alto] Sin logging de seguridad ni auditoría	Repudiation	High	Open		Solo hay console.log. Acciones de administrador y cambios de estado de órdenes no son trazables. Nivel de riesgo: Alto (puntaje 6). Categorías STRIDE: R. Evidencia: payment.service.js, server.js.	Logging estructurado centralizado con usuario, IP y acción; SIEM y alertas.
17	T17 [Bajo] Mass assignment en productos	Tampering	Low	Open		createProduct y updateProduct aceptan campos arbitrarios (slug, is_active, image_url). Nivel de riesgo: Bajo (puntaje 2). Categorías STRIDE: T, E. Evidencia: product.service.js.	Lista blanca de campos permitidos.
21	T21 [Bajo] Subida de imágenes validada solo por tipo declarado	Tampering	Low	Open		La validación depende del formato declarado y de Cloudinary; riesgo si la cuenta admin se compromete. Nivel de riesgo: Bajo (puntaje 2). Categorías STRIDE: T. Evidencia: cloudinary.utils.js.	Validar tipo real (magic bytes), límites y escaneo.

P9 Swagger UI (Process)

Description: /api/docs (componente C05).

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	T09 [Medio] Swagger expuesto en producción	Information disclosure	Medium	Open		/api/docs accesible sin autenticación y documenta todos los endpoints. Nivel de riesgo: Medio (puntaje 4). Categorías STRIDE: I. Evidencia: app.js.	Deshabilitar en producción o protegerlo con autenticación.

P10 Contenedores y dependencias (Process)

Description: Docker Compose, imágenes y paquetes npm (C08, C09).

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	T13 [Medio] Contenedores root y secretos en variables de entorno	Elevation of privilege	Medium	Open		Contenedores sin USER no root, secretos en variables de entorno, migraciones y seeders en cada arranque. Nivel de riesgo: Medio (puntaje 3). Categorías STRIDE: E. Evidencia: Dockerfile, docker-compose.yml.	USER node, escaneo de imágenes, Docker secrets o Vault, migraciones fuera del arranque.
22	T22 [Alto] Cadena de suministro sin controles	Tampering	High	Open		Sin SCA, sin pruebas ni CI, versiones con ^ en package.json. Nivel de riesgo: Alto (puntaje 6). Categorías STRIDE: T. Evidencia: package.json.	npm audit/SCA y SAST en CI, lockfile, Dependabot, pruebas automatizadas.

DS1 MySQL (Store)

Description: users, products, categories, carts, cart_items, orders, order_items.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
12	T12 [Alto] MySQL expuesto y usuario root	Elevation of privilege	High	Open		El puerto 3306 está publicado y el README usa DB_USER=root. Nivel de riesgo: Alto (puntaje 8). Categorías STRIDE: E, I, T. Evidencia: docker-compose.yml, README.	No publicar 3306, usuario de BD con mínimo privilegio, red interna Docker, TLS a la BD.

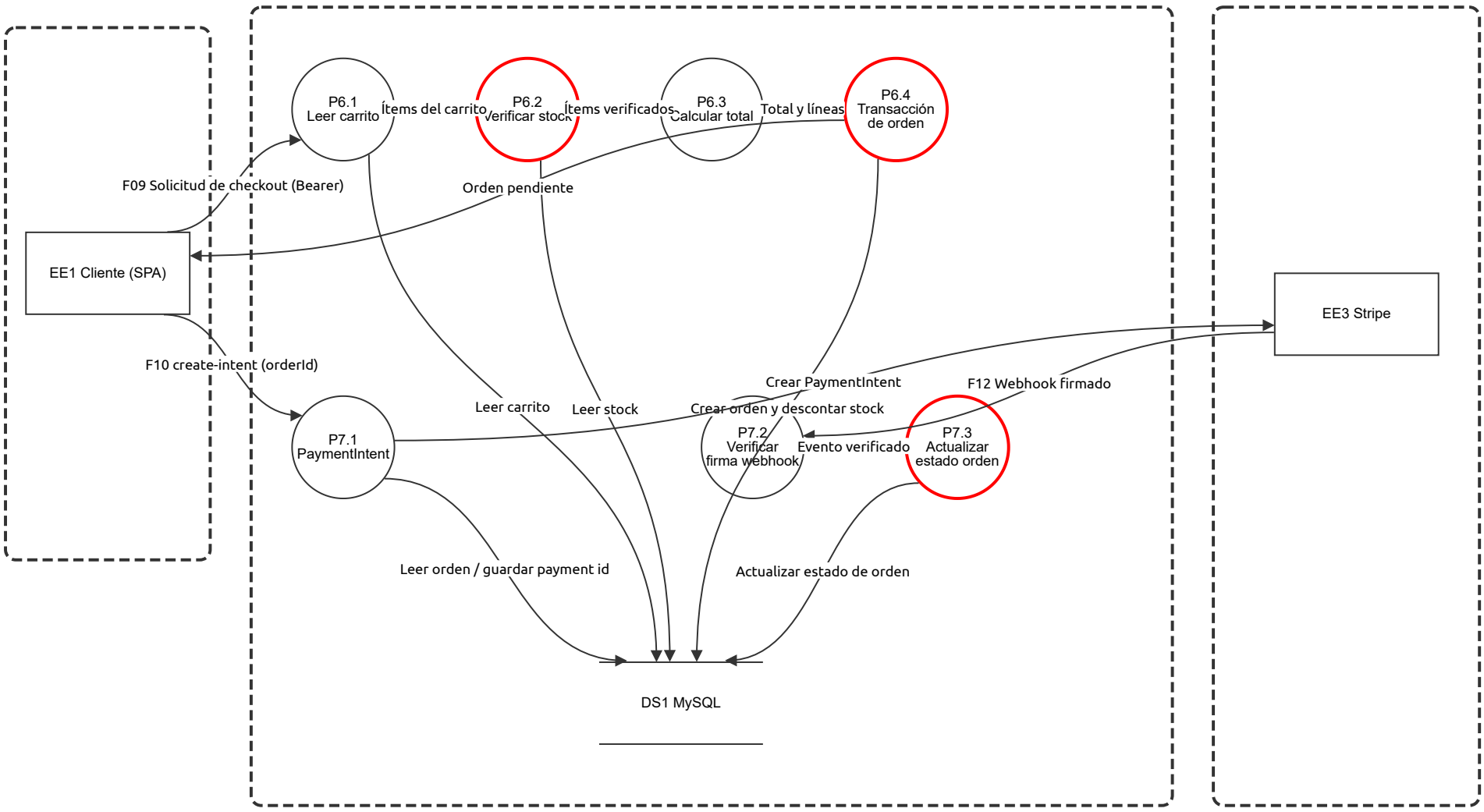
EE3 Stripe (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

EE4 Cloudinary (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

DFD Nivel 2 - Checkout y pago



DFD Nivel 2 - Checkout y pago

EE1 Cliente (SPA) (Actor)

Description: SPA autenticada con Bearer.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P6.1 Leer carrito (Process)

Description: Obtiene el carrito del userId del JWT.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P6.2 Verificar stock (Process)

Description: Lee stock por ítem, fuera de la transacción.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	T06 [Alto] Condición de carrera en stock del checkout	Tampering	High	Open		La verificación de stock se hace fuera de la transacción y el descuento es lectura-modificación-escritura sin bloqueo: sobreventa. Nivel de riesgo: Alto (puntaje 6). Categorías STRIDE: T. Evidencia: order.service.js.	SELECT ... FOR UPDATE o decremento atómico condicional; CHECK stock >= 0.

P6.3 Calcular total (Process)

Description: Usa el precio de BD y la cantidad del carrito.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P6.4 Transacción de orden (Process)

Description: Crea orden, descuenta stock; clearCart queda fuera.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	T07 [Alto] Stock retenido por órdenes pendientes	Denial of service	High	Open		El checkout descuenta stock sin pago y las órdenes pending no expiran; payment_failed cancela sin reponer stock. Nivel de riesgo: Alto (puntaje 6). Categorías STRIDE: D. Evidencia: order.service.js, payment.service.js.	Expiración de órdenes pendientes con reposición de stock; límite de órdenes pendientes por usuario.

P7.1 PaymentIntent (Process)

Description: Crea o reutiliza PaymentIntent con idempotencyKey.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P7.2 Verificar firma webhook (Process)

Description: stripe.webhooks.constructEvent con el secret.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

P7.3 Actualizar estado orden (Process)

Description: Marca paid o cancelled por stripe_payment_id.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
14	T14 [Medio] Webhook sin idempotencia ni validación de estado/monto	Tampering	Medium	Open		El webhook no deduplica por event.id, no valida estado previo ni monto, y es un endpoint público sin límites. Nivel de riesgo: Medio (puntaje 3). Categorías STRIDE: T, D. Evidencia: payment.service.js, app.js.	Idempotencia por event.id, validar estado y monto, rate limiting.

DS1 MySQL (Store)

Description: Tablas carts, products, orders, order_items.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

EE3 Stripe (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F09 Solicitud de checkout (Bearer) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Leer carrito (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Ítems del carrito (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Leer stock (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Ítems verificados (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Total y líneas (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Crear orden y descontar stock (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Orden pendiente (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F10 create-intent (orderId) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Leer orden / guardar payment id (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Crear PaymentIntent (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

F12 Webhook firmado (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Evento verificado (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Actualizar estado de orden (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations